Saudi GRC Platform

Test Cases

Source: `test-cases.md`

15 — Test Cases and UAT Scenarios

Per-workflow test cases for UAT. Each case has: ID, scenario, preconditions, steps, expected result, role, pass/fail criteria.

TC-BIA-001 — Score a new BIA and approve

- **Scenario**: New service requires a BIA cycle.
- **Preconditions**: critical service exists; user is BIA Owner.
- **Steps**: 1. Navigate to `/bcm`, click BIA tab, click "New BIA". 2. Select service. Fill impact dimensions, MTPD 24h, RTO 4h, RPO 1h. 3. Add dependency on `DB-PRIMARY`. 4. Save → submit for review. 5. BCM Manager logs in, opens BIA, clicks Approve.
- **Expected**: BIA status APPROVED; signature transaction created; audit event logged; evidence link created.
- **Role**: BIA Owner → BCM Manager.
- **Pass/fail**: status APPROVED + signed evidence visible.

TC-BCP-001 — Build, peer-review, approve BCP

- **Scenario**: New BCP for a critical service.
- **Preconditions**: BIA APPROVED.
- **Steps**: draft BCP → peer review → BCM approves → publish ACTIVE.
- **Expected**: BCP ACTIVE; PDF generated; linked to evidence.

TC-DRP-001 — DR plan creation, approval, test

- **Scenario**: New DR plan, test it, record outcome.
- **Steps**: create DR plan → review → approve → run test action `recordTest(outcome=PASS_WITH_OBSERVATIONS)`.
- **Expected**: DR plan ACTIVATED; test outcome captured; next-test-due set.

TC-VENDOR-RISK-001 — Vendor onboarding risk assessment

- **Scenario**: New vendor risk assessment.
- **Steps**: create vendor → trigger KYC → run risk assessment → score HIGH → approve.
- **Expected**: vendor ACTIVE with risk HIGH; reassessment due 12 months.

TC-SUPP-INC-001 — Supplier incident escalation

- **Scenario**: Vendor reports incident.
- **Steps**: log incident → assess impact → if critical-service affected, invoke BCP.
- **Expected**: incident logged; if BCP invoked, crisis-management notified.

TC-ERM-RA-001 — ERM risk assessment

- **Scenario**: Identify and assess a new risk.
- **Steps**: add new risk → assess L×I → calculate inherent + residual → approve.
- **Expected**: risk status ASSESSED → APPROVED.

TC-ERM-ACC-001 — Risk acceptance above appetite

- **Scenario**: Risk residual > appetite; formal acceptance.
- **Steps**: open above-appetite risk → request acceptance → CRO signs → ACTIVE.
- **Expected**: acceptance status ACTIVE; digital signature transaction recorded; expiry 12m.

TC-NCA-CTRL-001 — NCA control assessment

- **Scenario**: Annual ECC control assessment.
- **Steps**: open control → score implementation → upload evidence → approve.
- **Expected**: control implementation status updated; evidence linked; CISO sign-off.

TC-NCA-EVID-EXP-001 — NCA evidence expiry

- **Scenario**: Evidence approaching expiry triggers notification.
- **Preconditions**: NCA control evidence with expiry 30d out.
- **Steps**: wait for scheduled job (or trigger manually).
- **Expected**: evidence flagged EXPIRING_SOON; both owners notified; renewal CAPA created if not actioned by expiry.

TC-CYBER-BREACH-001 — Cyber incident to PDPL breach

- **Scenario**: Cyber incident impacts PII.
- **Steps**: open cyber incident → mark impacted-assets with `pii=true` → transition to ANALYSIS.
- **Expected**: `CyberPdplBridgeService` auto-creates DataBreach record; 72h timer started; DPO + CISO notified; bridge-log row written.

TC-PIA-001 — New high-risk PIA

- **Scenario**: New high-risk processing activity.
- **Steps**: create PIA → run risk assessment → DPO + CISO sign → APPROVED.
- **Expected**: PIA APPROVED with signatures; linked to ROPA.

TC-DSR-001 — Data subject request fulfilment

- **Scenario**: Subject submits DSR.
- **Steps**: receive request via portal → triage → fulfil within 30d → respond with sign.
- **Expected**: DSR FULFILLED before day-30 SLA; response signed by DPO; audit logged.

TC-CBT-001 — Cross-border transfer approval

- **Scenario**: Request CBT to USA via SCC.
- **Steps**: request → DPO assesses → approve.
- **Expected**: CBT APPROVED; expiry set; ROPA linked.

TC-BREACH-001 — Personal data breach 72-hour notification

- **Scenario**: Breach detected.
- **Steps**: detect → contain → assess → notify SDAIA within 72h → close.
- **Expected**: breach NOTIFIED within 72h; SDAIA notification reference recorded; DPO signature on notification.

TC-SIG-001 — Digital signature approval

- **Scenario**: User signs a policy.
- **Steps**: signature transaction REQUESTED → user opens inbox → reviews → signs.
- **Expected**: SIGNED status; SHA-256 hash bound to payload; certificate-reference stored.

TC-BOARD-001 — Board report generation

- **Scenario**: Quarterly board pack.
- **Steps**: Board Secretary opens Board Pack → generate PDF → Chairman reviews → Chairman signs → distribute.
- **Expected**: PDF generated; signature transaction SIGNED; distribution event fired to board members.

TC-EVID-PKG-001 — Regulatory evidence package generation

- **Scenario**: NCA requests evidence pack.
- **Steps**: open NCA filing → click "Export evidence package" → ZIP generated.
- **Expected**: ZIP containing per-control evidence + chain verification report + signed cover.

TC-FOURTHP-CONC-001 — Fourth-party concentration triggers CAPA

- **Scenario**: A fourth party appears behind ≥3 primaries.
- **Steps**: create 3 fourth-party rows for the same `fourthPartyName` → observe concentration recompute.
- **Expected**: concentrationRisk auto-elevates to HIGH; automation service auto-opens a CAPA; CAPA visible in `/capa` with `originType=fourth_party_exposure`, severity HIGH, target +30d.

TC-PROC-FAIL-001 — Failed processor assessment opens CAPA

- **Scenario**: Score a processor assessment with one control = FAIL.
- **Steps**: open IN_PROGRESS assessment → submit score with c4 FAIL → watch outcome derive to FAIL → COMPLETED.
- **Expected**: overall outcome FAIL; automation service auto-opens CAPA; CAPA severity CRITICAL.

TC-SRT-FAIL-001 — Failed resilience test opens CAPA

- **Scenario**: Complete a resilience test with FAIL outcome.
- **Steps**: start scheduled test → complete with `outcome=FAIL`, observations + action items.
- **Expected**: test COMPLETED with FAIL; automation service auto-opens CAPA `originType=supplier_resilience_test`, severity HIGH, target +60d.

TC-EVCHAIN-001 — Evidence chain verification

- **Scenario**: Verify SHA-256 chain.
- **Steps**: open evidence item → click Verify chain.
- **Expected**: chain status flips UNVERIFIED → VALID; report shows per- version hash trail; broken chain (if any) flagged.

Cross-cutting checks (every workflow)

- Tenant isolation: a user from org A cannot see org B records.

- Bilingual: every screen + every report renders cleanly in both AR (RTL) and EN (LTR).
- Audit log: every transition writes an `audit.events` row.
- Realtime: a list page open in one browser refreshes when another browser changes a record.
- Soft-delete: a "deleted" record disappears from all reads.
- API contracts: every endpoint matches OpenAPI spec.